Μηχανικών Η/Υ και Πληροφορικής(CEID)
Πολυτεχνική Σχολή πανεπιστημίου Πατρών

Εξαμηνιαία Εργασία 2025-2026

Στοιχεία Ομάδας:

ΑΜ	Ον/μο	Email	Έτος
1100557	Χριστόφορος Θεοδοσόπουλος	up1100557@upnet.gr	4ο

Επιλογή από τα Προτεινόμενα Θέματα: (1.) Amazon Cognito

Πήγες:

https://docs.aws.amazon.com/cognito/latest/developerguide/what-is-amazon-cognito.html

https://aws.amazon.com/cognito/

https://aws.amazon.com/cognito/features/

Αναλυτική περιγραφή και τεκμηρίωση

Το Amazon Cognito είναι μια πλατφόρμα ταυτότητας για εφαρμογές ιστού και κινητών. Είναι ένας κατάλογος χρηστών, ένας διακομιστής ελέγχου ταυτότητας και υπηρεσία εξουσιοδότησης για διακριτικά πρόσβασης OAuth 2.0 και AWS διαπιστευτήρια.Το Amazon Cognito επιτρέπει την προσθήκη εγγραφής χρήστη, είσοδο και έλεγχο πρόσβασης στις εφαρμογές web και mobile. Είναι μια υπηρεσία με επίκεντρο τον προγραμματιστή, οικονομικά αποδοτική που παρέχει ασφαλή καταστήματα ταυτότητας που βασίζονται σε ενοικιαστές και επιλογές ομοσπονδίας που μπορούν να κλιμακωθούν σε εκατομμύρια χρήστες. Επιπλέον, Amazon

Bedrock AgentCore Identity το No.1, που υποστηρίζεται από το Amazon Cognito, επιτρέπει στους πράκτορες τεχνητής νοημοσύνης να έχουν ασφαλή πρόσβαση σε πόρους AWS ή εργαλεία και υπηρεσίες τρίτων με ισχυρούς ελέγχους πρόσβασης, ενώ παράλληλα εξορθολογίζει την ανάπτυξη πρακτόρων και την εμπειρία χρήστη. Επεξεργασία περισσότερων από 100 δισεκατομμυρίων ελέγχων ταυτότητας το μήνα, το Amazon Cognito παρέχει ολοκληρωμένη διαχείριση ταυτότητας πελατών και πρόσβασης (CIAM) τόσο για ανθρώπους χρήστες όσο και για ταυτότητες μηχανών.

Βασικά Χαρακτηριστικά:

User Authentication:

- **No-code, Branded Managed Login**

  Οι προγραμματιστές μπορούν να χρησιμοποιήσουν ένα οπτικό πρόγραμμα επεξεργασίας χωρίς κώδικα για να προσαρμόσουν τον τρόπο εμφάνισης των οθονών τελικού χρήστη (όπως εγγραφή, σύνδεση και MFA). Οι παράμετροι διαμόρφωσης περιλαμβάνουν χρώματα, τοποθέτηση, στοίχιση, κείμενο, γλώσσα, φόντο, εικόνες, λογότυπα, γραμματοσειρές και διάταξη, μεταξύ άλλων. Με αυτές τις επιλογές διαμόρφωσης, ένα στυλ επωνυμίας καταναλωτή μπορεί να ταιριάζει στενά και οι εμπειρίες χρήστη που παρέχει η Cognito μπορεί να είναι πιο συνεπείς και συνεκτικές με την υπόλοιπη εφαρμογή.

- **Passwordless Authentication**

  Οι πελάτες μπορούν να διαμορφώσουν το Amazon Cognito ώστε να επιτρέπει στους τελικούς χρήστες να έχουν πρόσβαση σε εφαρμογές χωρίς να χρειάζεται να θυμούνται έναν κωδικό πρόσβασης, να μειώνουν την τριβή, να βελτιώνουν την ασφάλεια και να αυξάνουν τη μετατροπή του χρήστη. Οι υποστηριζόμενες ροές ελέγχου ταυτότητας χωρίς κωδικό πρόσβασης περιλαμβάνουν σύνδεση με **email**, σύνδεση με **τηλέφωνο/SMS** και σύνδεση με **κλειδιά πρόσβασης**. Αυτή η ευελιξία ενισχύει την εμπειρία του χρήστη και απλοποιεί τη διαδικασία σύνδεσης.

- **WebAuthn passkeys**
  Τα κλειδιά πρόσβασης WebAuthn παρέχουν βελτιωμένη ασφάλεια εξαλείφοντας την ανάγκη για κωδικούς πρόσβασης, μειώνοντας τον κίνδυνο phishing και κλοπής διαπιστευτηρίων. Προσφέρουν μια απρόσκοπτη εμπειρία χρήστη με ταχύτερες και πιο βολικές μεθόδους

ελέγχου ταυτότητας, όπως **βιομετρικά στοιχεία ή μάρκες υλικού**. Επιπλέον, τα κλειδιά πρόσβασης βελτιώνουν τη συνολική ασφάλεια του λογαριασμού αξιοποιώντας την **κρυπτογραφία δημόσιου κλειδιού**, διασφαλίζοντας ότι οι ευαίσθητες πληροφορίες δεν μεταδίδονται ή αποθηκεύονται ποτέ σε διακομιστές. Το Amazon Cognito παρέχει και τα δύο **[Διαχειριζόμενη Σύνδεση]** και υποστήριξη API για δημιουργία και αποθήκευση έως και 20 κλειδιών πρόσβασης ανά λογαριασμό.

- **Multi-factor authentication (MFA)**

  Μπορείτε να προσθέσετε ένα επιπλέον επίπεδο ασφάλειας για τους πελάτες σας ενεργοποιώντας το MFA για λογαριασμούς χρηστών. Οι χρήστες μπορούν να επαληθεύσουν την ταυτότητά τους χρησιμοποιώντας email, SMS ή **μια γεννήτρια One-time Password (TOTP)** που βασίζεται στο χρόνο, όπως το Google Authenticator. Το Amazon Cognito υποστηρίζει επίσης τη διαμόρφωση διαφορετικών κανόνων κωδικού πρόσβασης σε διαφορετικές ομάδες χρηστών.

- **Federation**

  Ως ομοσπονδιακός κόμβος, το Amazon Cognito επιτρέπει στους χρήστες να συνδέονται μέσω παρόχων κοινωνικής ταυτότητας, όπως η Apple, το Facebook, η Google και η Amazon και πάροχοι εταιρικής ταυτότητας μέσω SAML και OID.Το Amazon Cognito υποστηρίζει μια ποικιλία προφίλ SAML, συμπεριλαμβανομένων ροών που ξεκινούν από **SAML SP, ροές που ξεκινούν από το IdP και κρυπτογράφηση SAML**. Μόλις οι χρήστες σας συνδεθούν στο Amazon Cognito (μέσω τοπικού ελέγχου ταυτότητας ή εξωτερικής ομοσπονδίας), μπορούν να χρησιμοποιήσουν το **OAuth/OIDC** για πρόσβαση σε ομοσπονδιακούς πόρους.

- **Custom Authentication**

  Το Amazon Cognito σάς επιτρέπει να δημιουργείτε προσαρμοσμένες ροές ελέγχου ταυτότητας που χρησιμοποιούν συναρτήσεις **AWS Lambda** για τον έλεγχο ταυτότητας των χρηστών με βάση έναν ή περισσότερους κύκλους πρόκλησης-απόκρισης. Μπορείτε να χρησιμοποιήσετε αυτήν τη ροή για να εφαρμόσετε προσαρμοσμένα σχήματα ελέγχου ταυτότητας που βασίζονται σε προσαρμοσμένες προκλήσεις ή να χρησιμοποιήσετε προσαρμοσμένες προκλήσεις ως πρόσθετους παράγοντες.

- **Customizing user workflows with Lambda triggers**

  Χρησιμοποιήστε εναύσματα AWS Lambda για να προσαρμόσετε τη συμπεριφορά Cognito, συμπεριλαμβανομένων σταδίων κύκλου ζωής χρήστη όπως πριν και μετά τον έλεγχο ταυτότητας και την εγγραφή ή πριν από την έκδοση διακριτικών. Μπορείτε επίσης να χρησιμοποιήσετε **εναύσματα Lambda** για να προσαρμόσετε μηνύματα που

αποστέλλονται σε χρήστες σε διαφορετικά στάδια ή για να ενσωματωθούν σε τρίτους παρόχους email και SMS.

Identity Management:

- **Self-registration**

  Η πρώτη εμπειρία ενός πελάτη με τον ιστότοπό σας είναι συχνά μέσω της διαδικασίας **αυτοεγγραφής**. Το Amazon Cognito παρέχει τόσο μια προσαρμόσιμη, προσυσκευασμένη, διαχειριζόμενη διεπαφή σύνδεσης για γρήγορη κυκλοφορία στην αγορά όσο και ένα ισχυρό σύνολο API για τη δημιουργία μιας πλήρως προσαρμοσμένης λύσης αυτοεγγραφής. Οι χρήστες μπορούν να εγγραφούν χρησιμοποιώντας ένα email, έναν αριθμό τηλεφώνου ή ένα όνομα χρήστη για την εφαρμογή σας. Η διαδικασία αυτοεγγραφής δίνει τη δυνατότητα στους χρήστες να προβάλλουν και να ενημερώνουν τα δεδομένα του προφίλ τους, συμπεριλαμβανομένων των προσαρμοσμένων χαρακτηριστικών. Έτσι, μειώνει τις κλήσεις γραφείου βοήθειας με επιλογές **αυτοεξυπηρέτησης**, όπως επαναφορά κωδικού πρόσβασης με μήνυμα SMS ή email.

- **Tenant-based identity stores (user pools)**

  - Το Amazon Cognito παρέχει **ασφαλή καταστήματα ταυτότητας** που βασίζονται σε ενοικιαστές (**user pools**) που κλιμακώνονται σε εκατομμύρια χρήστες. Οι ομάδες χρηστών αποθηκεύουν με ασφάλεια δεδομένα προφίλ χρήστη για χρήστες που εγγράφονται απευθείας και για ομοσπονδιακούς χρήστες που συνδέονται με εξωτερικούς παρόχους ταυτότητας.Ένα παράδειγμα, είναι το **Amazon Cognito IDENTity store** είναι ένα αποθετήριο χρηστών που βασίζεται σε API. Το αποθετήριο και τα API υποστηρίζουν την αποθήκευση έως και **50 προσαρμοσμένων χαρακτηριστικών ανά χρήστη**, την υποστήριξη για διαφορετικούς τύπους δεδομένων και την επιβολή περιορισμών μήκους και μεταβλητότητας. Επιλέξτε τα απαιτούμενα χαρακτηριστικά που πρέπει να παρέχονται από τον χρήστη πριν από την ολοκλήρωση της διαδικασίας εγγραφής.

- **Migration options**
  Οι χρήστες μπορούν να μετεγκατασταθούν στο Amazon Cognito χρησιμοποιώντας μετεγκατάσταση είτε **ομαδικής εισαγωγής** είτε **έγκαιρης μετεγκατάστασης (JIT)**. Η μετεγκατάσταση χρήστη δέσμης αξιοποιεί μια διαδικασία εισαγωγής αρχείων CSV. Χρησιμοποιώντας τη διαδικασία μετεγκατάστασης JIT, μια ενεργοποίηση AWS Lambda ενσωματώνει τη διαδικασία μετεγκατάστασης στη ροή εργασίας σύνδεσης και μπορεί να διατηρήσει τους κωδικούς πρόσβασης των χρηστών.
- **Multi-tenancy and tenant isolation**

Το Amazon Cognito επιτρέπει αλληλεπιδράσεις **B2B** με υποστήριξη πολλών ενοικιαστών. Μπορείτε να επιλέξετε να επαναχρησιμοποιήσετε τις ενσωματώσεις εφαρμογών, τις πολιτικές πρόσβασης και κωδικού πρόσβασης ή να επιβάλετε πλήρη απομόνωση ενοικιαστή.

Access Control:

- **Last mile integration with applications**

  Το Amazon Cognito εξασφαλίζει το τελευταίο μίλι ενσωμάτωσης με μια εφαρμογή. Οι πύλες **AWS AppSync**, Amazon Application Load Balancers (**ALBs**) και Amazon API διαθέτουν ενσωματωμένα σημεία επιβολής πολιτικής που παρέχουν πρόσβαση με βάση τα διακριτικά και τα πεδία Amazon Cognito.

- **Fine-grained authorization**

  Χρησιμοποιώντας τη γρήγορη εκκίνηση των δικαιωμάτων Amazon Verified, οι πελάτες μπορούν να δημιουργήσουν αυτόματα πολιτικές δικαιωμάτων, να εκχωρήσουν έλεγχο πρόσβασης βάσει ρόλων με βάση τις συνδρομές της ομάδας Cognito και να επιβάλουν **λεπτομερή εξουσιοδότηση**. Το Amazon Verified Permissions διαθέτει ενσωματωμένο εξουσιοδοτητή διακριτικών που υποστηρίζει Amazon Cognito ID και διακριτικά πρόσβασης, συμπεριλαμβανομένων σύνθετων κατασκευών διακριτικών σε ένα διακριτικό.

- **Access AWS resources**

  Ο μεσίτης διαπιστευτηρίων για το Amazon Cognito, γνωστός και ως δεξαμενές ταυτότητας Amazon Cognito, παρέχει ενιαία πρόσβαση σύνδεσης σε πόρους AWS όπως Amazon DynamoDB, κουβάδες Amazon S3 buckets, στοιχεία χωρίς διακομιστή AWS Lambda και άλλες υπηρεσίες Amazon. Οι χρήστες μπορούν να αντιστοιχιστούν δυναμικά σε διαφορετικούς ρόλους για να υποστηρίξουν την πρόσβαση με τα **λιγότερα προνόμια** σε μια υπηρεσία.

- **Machine-to-machine authentication**

  Χρησιμοποιώντας το OAuth Client Credential Flow, το Amazon Cognito παρέχει έλεγχο ταυτότητας από μηχανή σε μηχανή, διασφαλίζοντας μια ασφαλή εμπειρία μεταξύ των στοιχείων της εφαρμογής.

- **ID / Access token customization**

  Εμπλουτίστε το ID και τα διακριτικά πρόσβασης με προσαρμοσμένα χαρακτηριστικά με τη μορφή πεδίων και αξιώσεων OAuth 2.0. Μπορείτε να λάβετε προηγμένες αποφάσεις εξουσιοδότησης για συγκεκριμένες εφαρμογές χρησιμοποιώντας προσαρμοσμένα χαρακτηριστικά στο διακριτικό πρόσβασης. Αυτή η δυνατότητα σάς επιτρέπει επίσης να

εξατομικεύσετε τις εμπειρίες των τελικών χρηστών και να βελτιώσετε την αφοσίωση των πελατών.

Customer Experience:

- **Customer outreach**

  Το Amazon Pinpoint παρέχει αναλύσεις για δραστηριότητες χρηστών που βασίζονται στο Amazon Cognito και το Amazon Cognito εμπλουτίζει τα δεδομένα χρήστη για καμπάνιες Pinpoint. Έτσι, ο χρήστης συλλέγει δεδομένα βασισμένα σε μια προσέγγιση με σκοπό την απόκτηση και διατήρηση πελατών.

- **Business agility amplified**

  Το AWS Amplify είναι ένα σύνολο ειδικά κατασκευασμένων εργαλείων και δυνατοτήτων που επιτρέπει στους προγραμματιστές ιστού και κινητών τηλεφώνων να δημιουργούν γρήγορα και εύκολα εφαρμογές **πλήρους στοίβας** στο AWS, με την ευελιξία να αξιοποιούν το εύρος των υπηρεσιών AWS καθώς εξελίσσονται οι θήκες χρήσης σας. Με το Amplify, μπορείτε να διαμορφώσετε ένα backend εφαρμογών ιστού ή για κινητά με το Amazon Cognito, να συνδέσετε την εφαρμογή σας μέσα σε λίγα λεπτά, να δημιουργήσετε **οπτικά** ένα web frontend UI και να διαχειριστείτε εύκολα το περιεχόμενο της εφαρμογής εκτός της κονσόλας AWS. Αυτό έχει σαν αποτέλεσμα, την αποστολή ταχύτερη και αβαθμιδωτή χωρίς να απαιτείται τεχνογνωσία στο cloud.

- **Extensibility**

Οι λύσεις CIAM είναι προσαρμοσμένες λύσεις. Το Amazon Cognito παρέχει ένα ισχυρό σύνολο γάντζων(hooks) και επεκτάσεων για την **πλήρη προσαρμογή** του ελέγχου ταυτότητας, της εγγραφής και των ροών μετεγκατάστασης χρηστών. Για παράδειγμα, η ροή αυτοεγγραφής μπορεί να αυξηθεί με προσαρμοσμένους ελέγχους απόδειξης ταυτότητας και επαλήθευσης λογαριασμού και η διαδικασία σύνδεσης μπορεί να επεκταθεί για τη δημιουργία προσαρμοσμένων ροών ελέγχου ταυτότητας ή την τροποποίηση ενός **διακριτικού** πριν δημιουργηθεί. Το Amazon Cognito **SDK** είναι διαθέσιμο χρησιμοποιώντας Java, C++, PHP, Python, Golang, Ruby, .NET και JavaScript.

Advanced Security:

- **Protection from web vulnerabilities using AWS WAF**

  Με μια ενσωματωμένη ενσωμάτωση με το AWS Web Application Firewall (**AWS WAF**), το Amazon Cognito προσφέρει προηγμένες λειτουργίες ανίχνευσης bot που μπορούν να βοηθήσουν στη **διάσωση** του οργανισμού σας από την πληρωμή για

αυτοματοποιημένους λογαριασμούς και στη **μείωση** του αντίκτυπου των επιθέσεων bot.

- **Compromised credential protection**

  Το Amazon Cognito μπορεί να εντοπίσει και να αποτρέψει, σε πραγματικό χρόνο, την **επαναχρησιμοποίηση** παραβιασμένων διαπιστευτηρίων καθώς οι χρήστες εγγράφονται, συνδέονται ή αλλάζουν τον κωδικό πρόσβασής τους. Όταν το Amazon Cognito εντοπίζει ότι οι χρήστες έχουν εισαγάγει διαπιστευτήρια που έχουν παραβιαστεί αλλού, τους ζητά να αλλάξουν τον κωδικό πρόσβασής τους.

- **Risk-based adaptive authentication**

  Όταν το Amazon Cognito εντοπίζει **ασυνήθιστη δραστηριότητα σύνδεσης**, όπως προσπάθειες από νέες τοποθεσίες και συσκευές ή αδύνατες συνθήκες ταξιδιού με βάση τη γεωγραφική θέση IP, εκχωρεί μια **βαθμολογία κινδύνου** στη δραστηριότητα και επιτρέπει στον χρήστη να επιλέξει είτε να ζητήσει από τους χρήστες **πρόσθετη επαλήθευση** είτε να **αποκλείσει τη σύνδεση**. Έτσι, ενισχύετε η προστασία του λογαριασμού του και βελτιώνετε η εμπειρία σύνδεσης του με προσαρμοστικό έλεγχο ταυτότητας.

Auditing and Compliance

- **Logging and monitoring**

  Το Amazon Cognito υποστηρίζει **παρακολούθηση** με AWS CloudTrail, Amazon CloudWatch Metrics και Amazon CloudWatch Logs Insights. Με το CloudTrail μπορείτε να καταγράψετε κλήσεις API από την κονσόλα Amazon Cognito και από κλήσεις κώδικα στις λειτουργίες Amazon Cognito API. Με τις μετρήσεις CloudWatch μπορείτε να παρακολουθείτε, να αναφέρετε και να κάνετε αυτόματες ενέργειες σε περίπτωση συμβάντος σε σχεδόν πραγματικό χρόνο. Με το CloudWatch Logs Insights, μπορείτε να διαμορφώσετε το CloudTrail για να στέλνει συμβάντα στο CloudWatch για παρακολούθηση **αρχείων καταγραφής** Amazon Cognito CloudTrail.

- **Log streaming**

  Το Amazon Cognito προσφέρει προηγμένη καταγραφή για συμβάντα χρηστών, όπως είσοδο, εγγραφή και αλλαγές κωδικού πρόσβασης, καταγράφοντας λεπτομερή δεδομένα αιτημάτων, όπως επίπεδο κινδύνου, τοποθεσία, IP πηγής και πράκτορα

χρήστη. Οι πελάτες μπορούν να μεταδώσουν αυτά τα δεδομένα καταγραφής συμβάντων σε λύσεις συγκέντρωσης αρχείων καταγραφής Amazon CloudWatch, Amazon S3 ή τρίτων μέσω του Amazon Kinesis Data Firehose. Αυτό επιτρέπει την **ολοκληρωμένη παρακολούθηση και ανάλυση της δραστηριότητας των χρηστών**.

- **Compliance**

Το Amazon Cognito ευθυγραμμίζεται με πολλαπλές απαιτήσεις ασφάλειας και συμμόρφωσης, συμπεριλαμβανομένων εκείνων για οργανισμούς υψηλής ρύθμισης, όπως εταιρείες **υγειονομικής περίθαλψης και εμπόρους**. Το Amazon Cognito είναι κατάλληλο για HIPAA και συμβατό με PCI DSS, SOC και ISO/IEC 27001, ISO/IEC 27017, ISO/IEC 27018 και ISO 9001.

User Pools Vs Identity Pools

Χαρακτηριστικό γνώρισμα	**Περιγραφή**	**User Pools**	**Identity Pools**
OIDC identity provider	Έκδωση διακριτικών OIDC ID για έλεγχο ταυτότητας χρηστών εφαρμογών	✓	
User Directory	Αποθήκευση προφίλ χρηστών για έλεγχο ταυτότητας	✓	
Authorize API access	Έκδοση διακριτικών πρόσβασης για την εξουσιοδότηση πρόσβασης χρήστη σε API (συμπεριλαμβανομένων των λειτουργιών API αυτοεξυπηρέτησης προφίλ χρήστη), βάσεων δεδομένων και άλλων πόρων που δέχονται πεδία OAuth	✓	
IAM web identity authorization	Δημιουργία διακριτικών που μπορούν να ανταλλάσονται με το AWS STS για προσωρινά Διαπιστευτήρια AWS		✓
SAML 2.0 service provider & OIDC identity provider	Έκδοση προσαρμοσμένα διακριτικά OIDC με βάση αξιώσεις από ένα SAML 2.0 πάροχος ταυτότητας	✓	
OIDC relying party & OIDC identity provider	Έκδοση προσαρμοσμένα διακριτικά OIDC με βάση αξιώσεις από ένα OIDC πάροχος ταυτότητας	✓	
OAuth 2.0 relying party & OIDC identity provider	Έκδοση προσαρμοσμένα διακριτικά OIDC με βάση τα πεδία από το OAuth 2.0 κοινωνικοί πάροχοι όπως η Apple και η Google	✓	

SAML 2.0 service provider & credentials broker	Έκδοση προσωρινών διαπιστευτηρίων AWS με βάση αξιώσεις από SAML 2.0 πάροχος ταυτότητας		✓
OIDC relying party & credentials broker	Έκδοση προσωρινών διαπιστευτηρίων AWS με βάση αξιώσεις από OIDC πάροχος ταυτότητας		✓
Social provider relying party & credentials broker	Έκδοση προσωρινά διαπιστευτήρια AWS με βάση τα JSON web tokens από εφαρμογές προγραμματιστών με κοινωνικούς παρόχους όπως η Apple και η Google.		✓
Amazon Cognito user pool relying party & credentials broker	Έκδοση προσωρινά διαπιστευτήρια AWS με βάση τα JSON web tokens από τις πισίνες χρηστών Amazon Cognito		✓
Custom relying party & credentials broker	Έκδοση προσωρινών διαπιστευτηρίων AWS σε αυθαίρετες ταυτότητες, εξουσιοδοτημένο από τον προγραμματιστή IAM διαπιστευτήρια		✓
Authentication frontend service	Εγγραφή, διαχείριση και πιστοποίηση της ταυτότητας των χρηστών με διαχειριζόμενους είσοδος	✓	
API support for your own authentication UI	Δημιουργία, διαχείριση και έλεγχος ταυτότητας χρηστών μέσω αιτημάτων API στο υποστηριζόμενο AWS SDKs[1]	✓	
MFA	Μηνύματα SMS, TOTP ή τη συσκευή του χρήστη ως πρόσθετος παράγοντας ελέγχου ταυτότητας[1]	✓	
Security monitoring & response	Προστασία από κακόβουλη δραστηριότητα και ανασφαλείς κωδικών πρόσβασης[1]	✓	
Customize authentication flows	Δημιουργία του δικού του(του χρήστη) μηχανισμού ελέγχου ταυτότητας ή πρόσθεση προσαρμοσμένων βημάτων στις υπάρχουσες ροές[1]	✓	
User groups	Δημιουργία λογικών ομαδοποιήσεων χρηστών και μια ιεραρχία IAM διεκδικήσεις ρόλων όταν περνάτε μάρκες σε ομάδες ταυτότητας	✓	
Customize tokens	Προσαρμογή του αναγνωριστικού και των διακριτικών πρόσβασης με νέα, τροποποιημένα και καταπιεσμένες αξιώσεις και πεδία	✓	
AWS WAF web ACL	Παρακολούθηση και έλεγχος των αιτημάτων στο μπροστινό μέρος του ελέγχου ταυτότητας με AWS WAF	✓	
Customize user attributes	Αντιστοίχιση τιμών σε χαρακτηριστικά χρήστη και πρόσθεση των δικών του χαρακτηριστικών του χρήστη	✓	

Unauthenticated access	Έκδοση διαπιστευτηρίων ταυτότητας ιστού περιορισμένης πρόσβασης από το AWS STS χωρίς έλεγχο ταυτότητας		✓
Role-based access control	Επιλογή ενός ρόλο IAM για τον πιστοποιημένο χρήστη σας με βάση των ισχυρισμών τους και ρύθμιση της εμπιστοσύνης του ρόλου του χρήστη για περιορισμό της πρόσβασης σε web identity χρήστες		✓
Attribute-based access control	Μετατροπή των αξιώσεων των χρηστών σε κύριες ετικέτες για το AWS STS του σε προσωρινή περίοδος λειτουργίας και χρησιμοποιήστε τις πολιτικές IAM για να φιλτράρετε την πρόσβαση στους πόρους με βάση τον κύριο ετικέτες		✓

[1] Η λειτουργία δεν είναι διαθέσιμη σε ομοσπονδιακούς χρήστες.

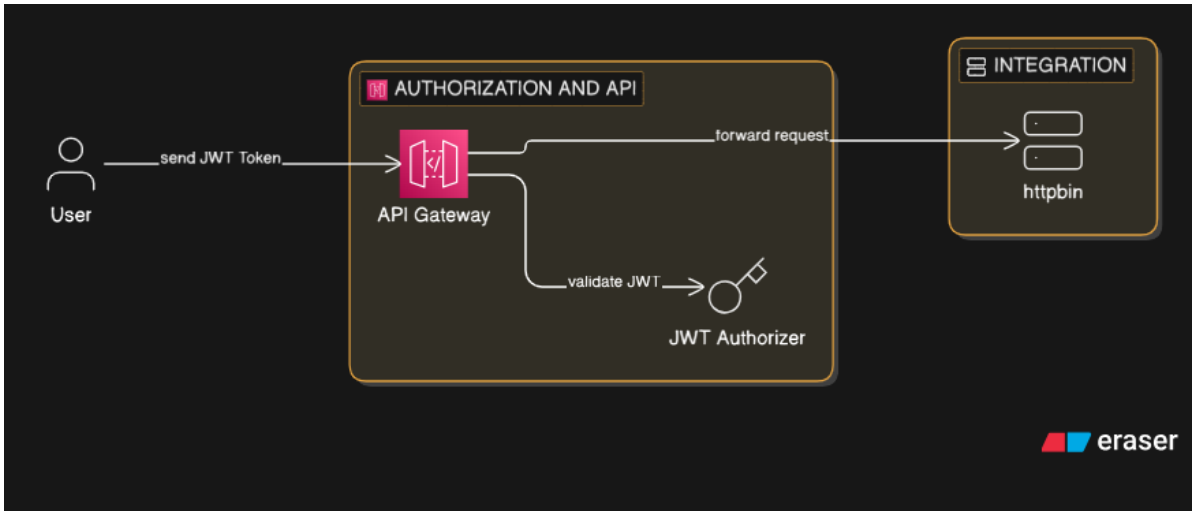
Πηγή: https://docs.aws.amazon.com/cognito/latest/developerguide/what-is-amazon-cognito.html

Case Study: Authentication και Authorization Web API με Amazon Cognito

Για την κάλυψη των απαιτήσεων, ρυθμίστηκε το Federation ώστε να επιτρέπεται η είσοδος με MFA Methods

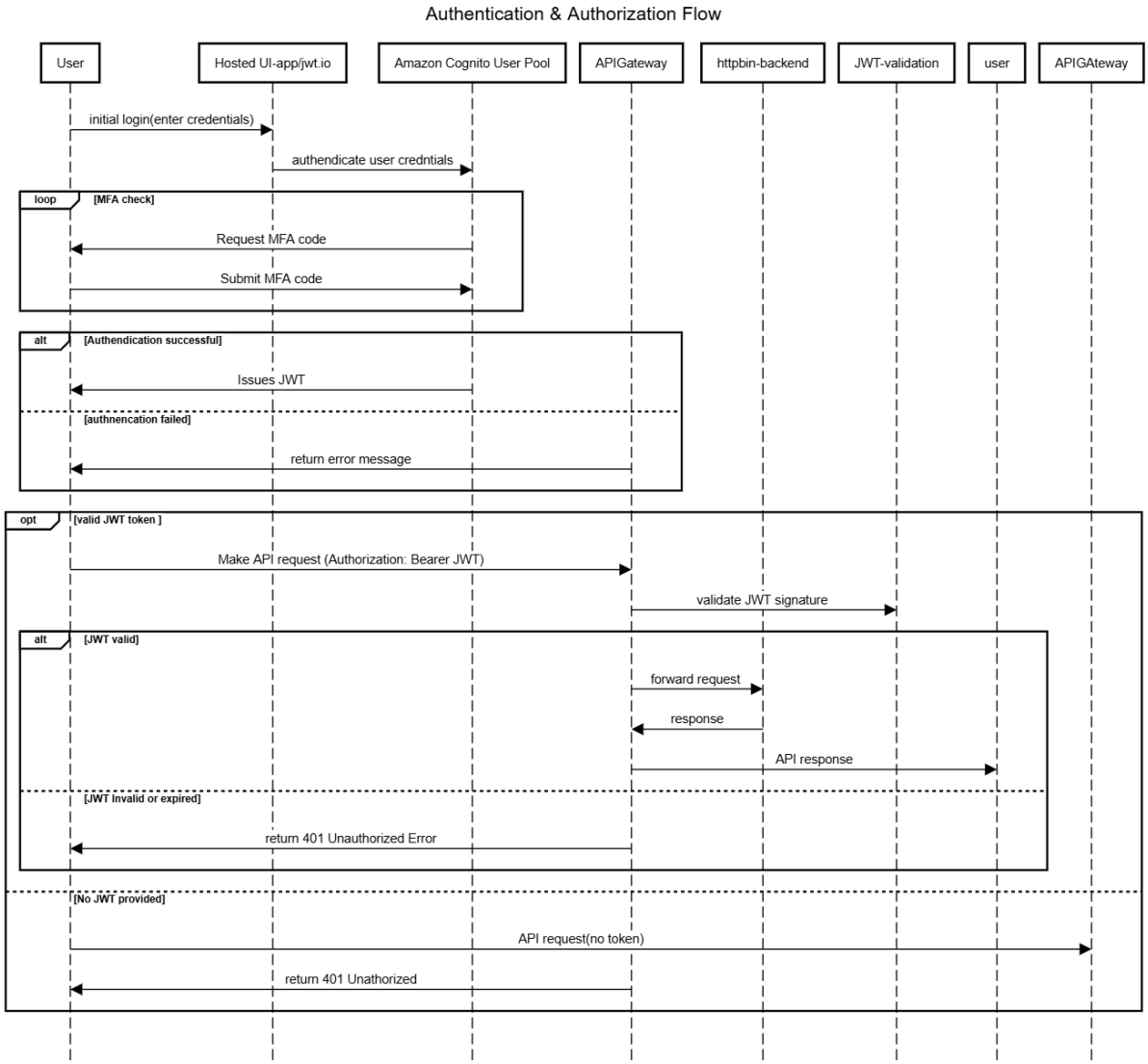
(SMS message,Authenticator apps) μέσω Google (Social Login), ενώ το Single Sign-On επιτρέπει στον χρήστη να παραμένει συνδεδεμένος σε διαφορετικές εφαρμογές του ίδιου User Pool. Στο παρόν case study υλοποιείται ένα σενάριο ασφαλούς πρόσβασης σε REST API, όπου η αυθεντικοποίηση των χρηστών πραγματοποιείται μέσω Amazon Cognito User Pool και η εξουσιοδότηση μέσω JWT tokens σε AWS API Gateway.Από παραμετροπιήσεις στο cognito προστέθηκε στο sign-in authentication το Device tracking και User account recovery.

Αρχιτεκτονική User pool case:



πηγή: https://app.eraser.io

Authentication & Authorization Flow Διάγραμμα:



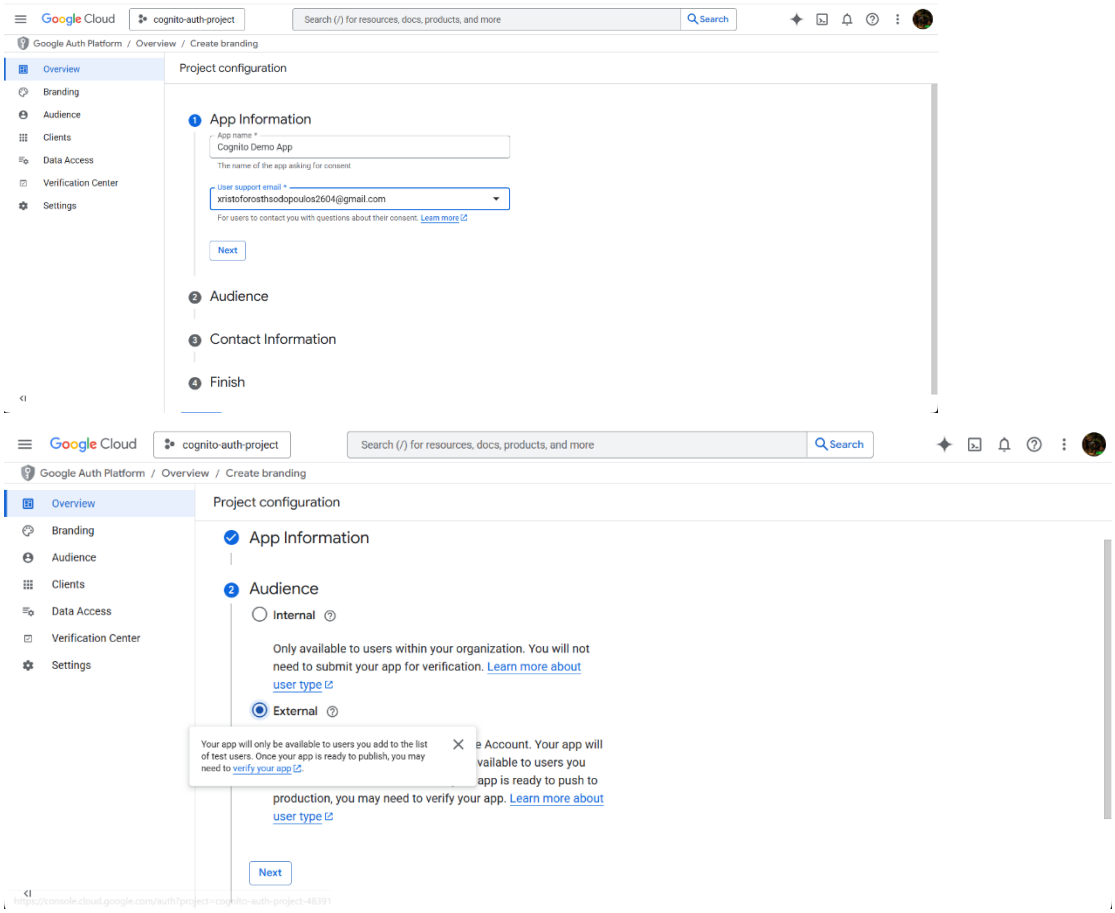
Πηγή: https://sequencediagram.org

Case Study:

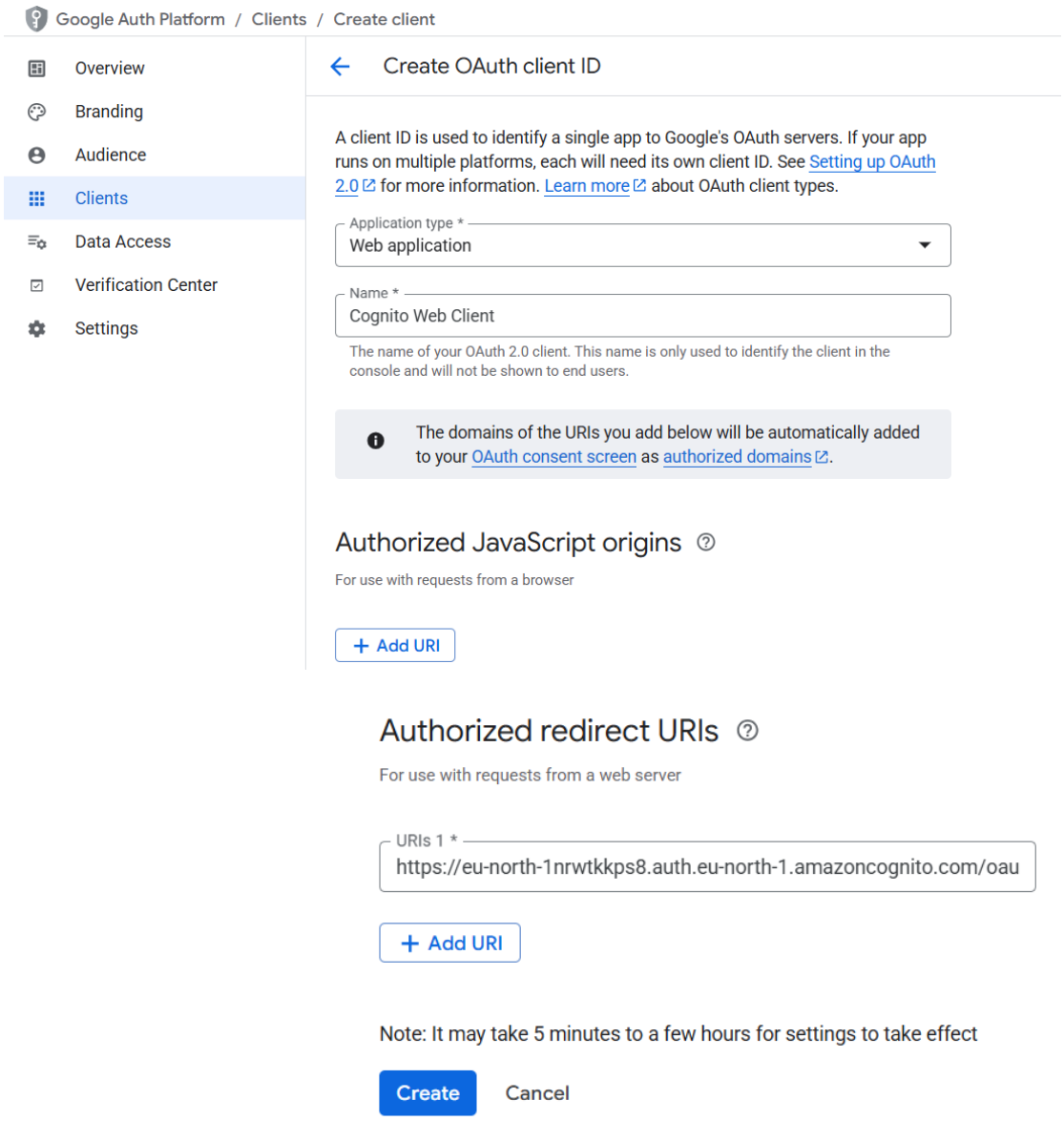
A. User Authentication (Cognito)

Δημιουργία ενός **User Pool** και ενός **App Client**. Ρύθμιση του Managed login domain για την παροχή σελίδας Login. Οι χρήστες αφού ταυτοποιηθούν, λαμβάνουν ένα **JWT Access Token**.

Βήματα για την δημιουργία ενός App Client μέσω του Google Cloud Console:

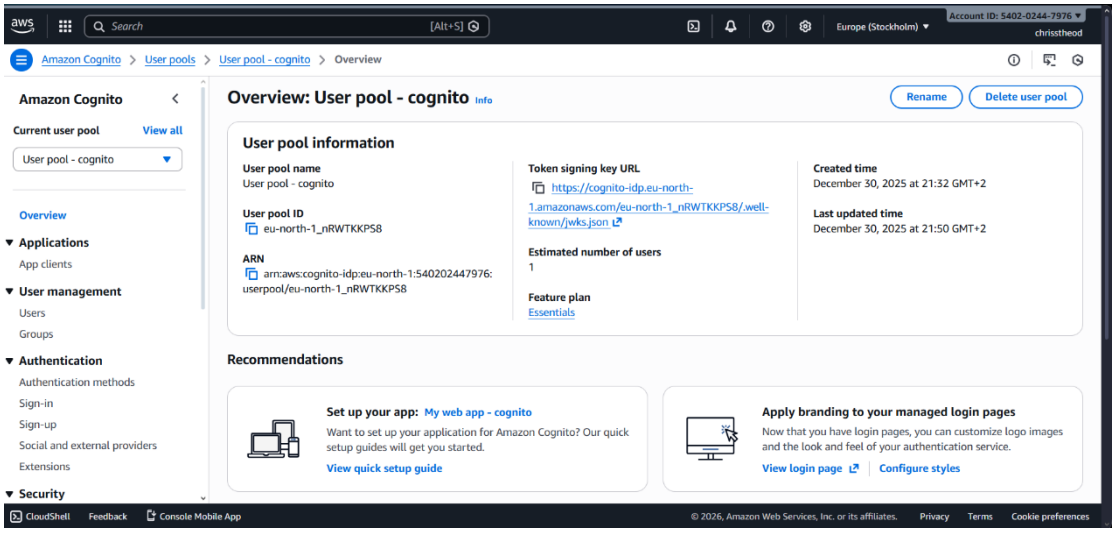


Εικόνα 1 και 2:Project configuration

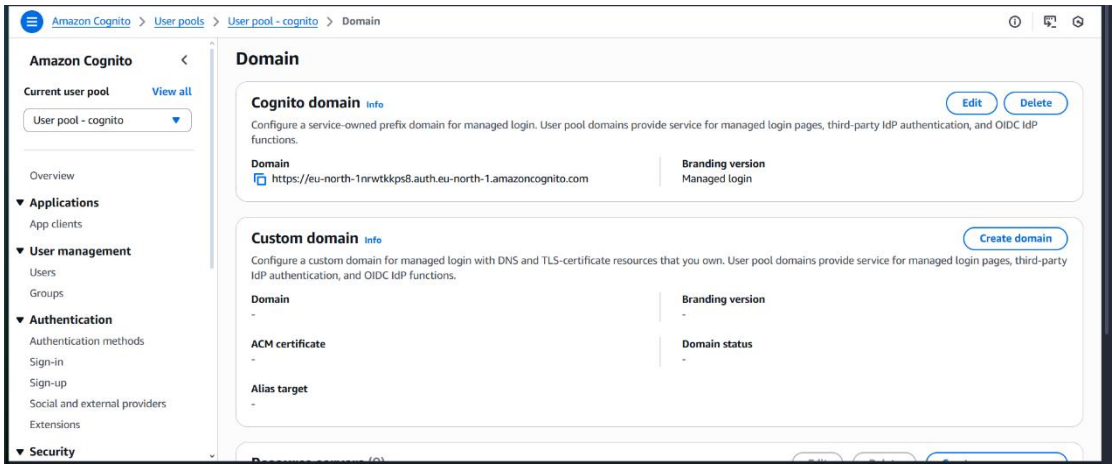


Εικόνα 3&4: Δημιουργία Client ID

Βήματα για την δημιουργία και αυθεντικοποίηση ενός user pool μέσα στο Cognito:

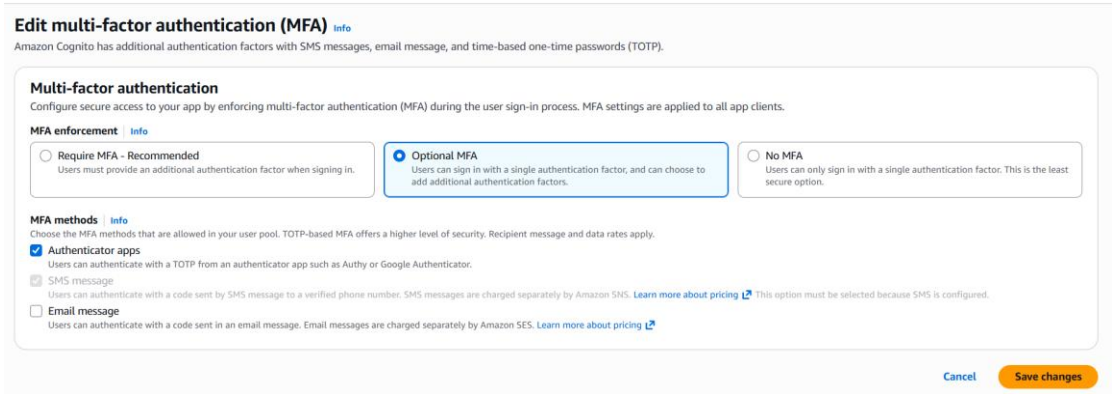


Εικόνα 5:User pool πληροφορίες



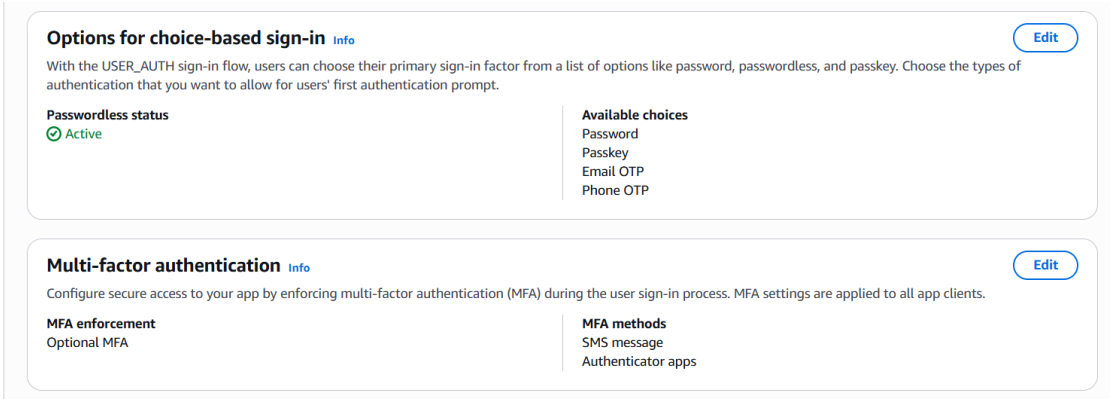
Εικόνα 6:Domain πληροφορίες

MFA μέθοδος:



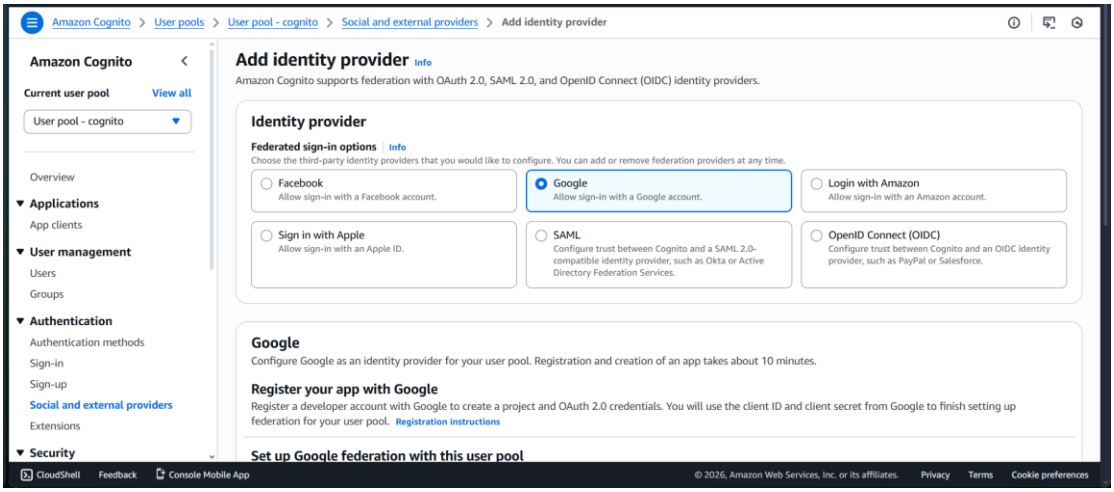
Εικόνα 7:MFA configuration

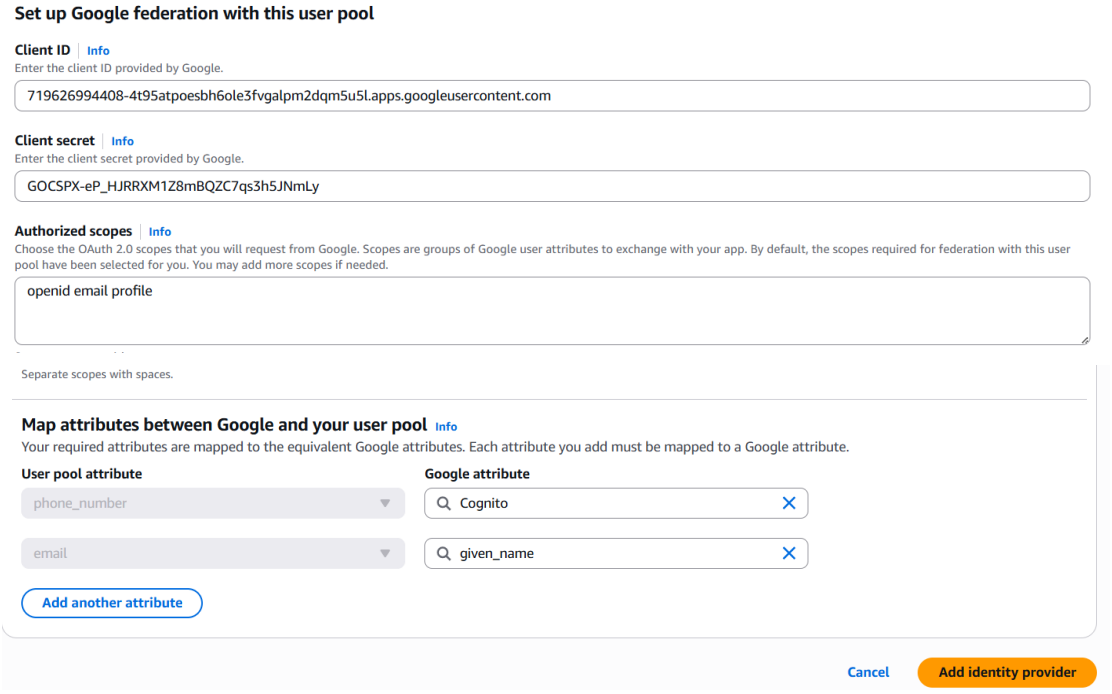
Single Sign-In authendication Methods:



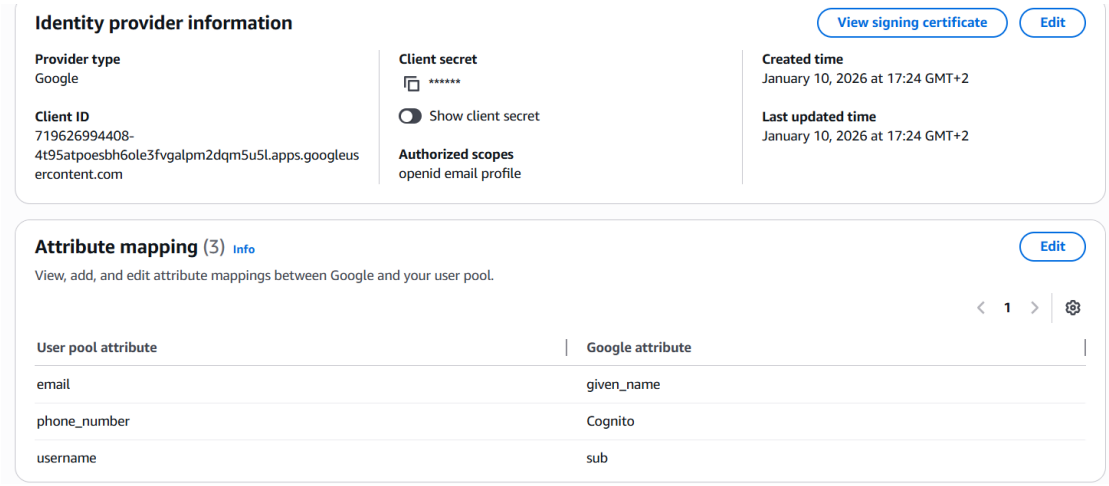
Εικόνα 8:επιλογές για single sign-in και πληροφορίες για MFA μεθόδους

Social Login In:



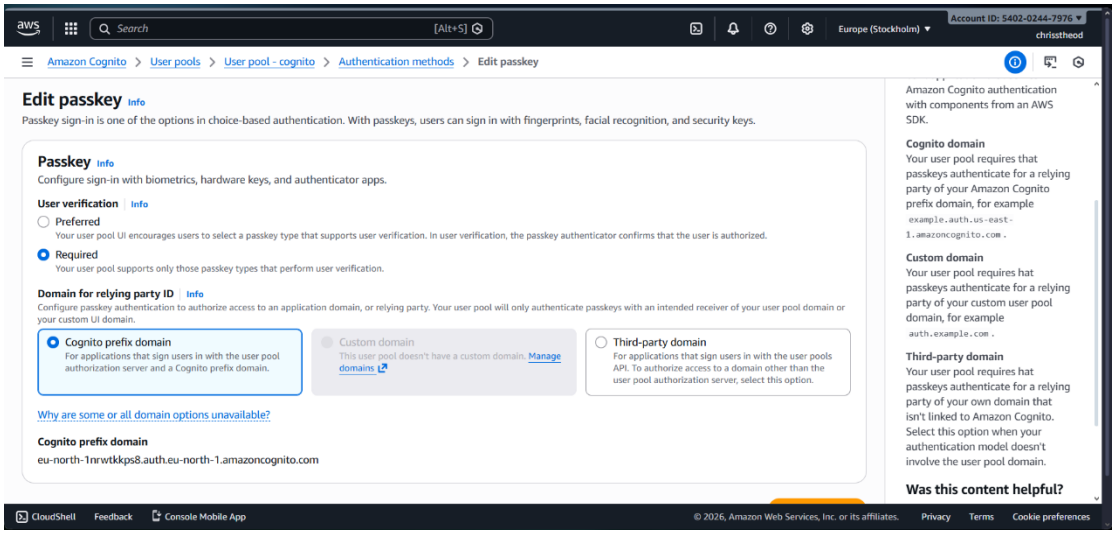


Εικόνα 9,10 & 11: Identity Provider configuration

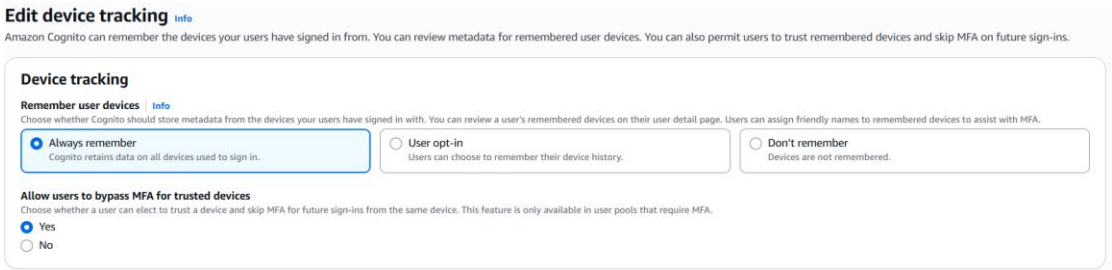


Εικόνα 12:Identity provider πληροφορίες

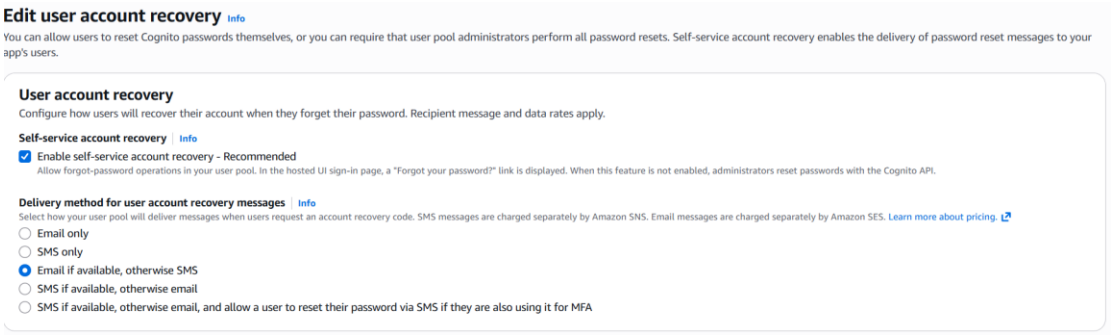
Δημιουργία passkey:



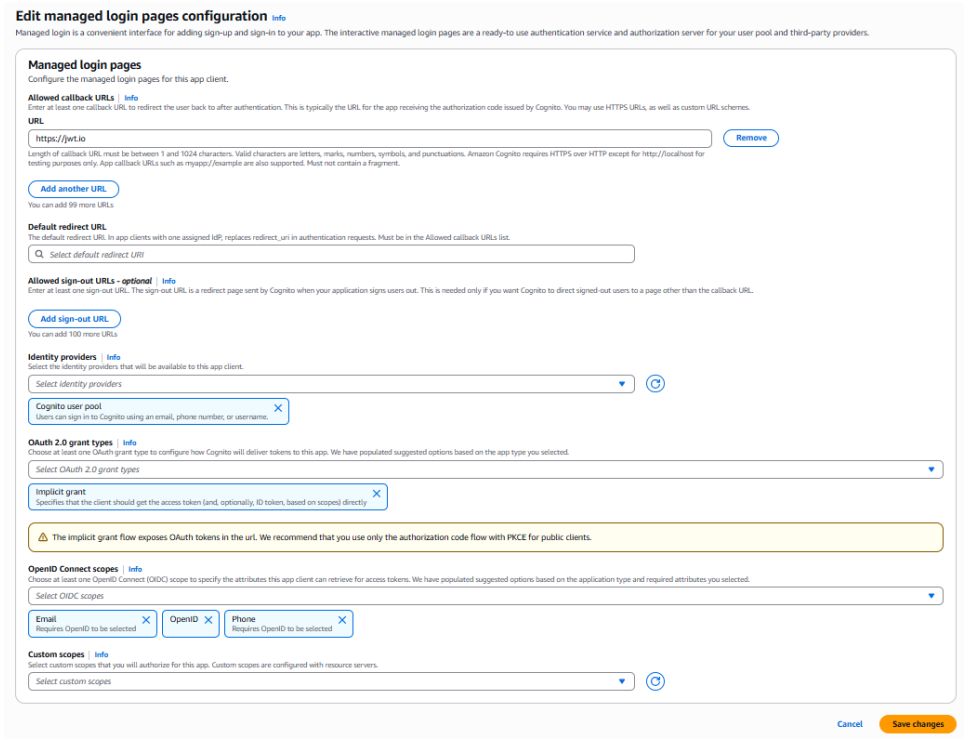
Εικόνα 13: passkey configuration



Εικόνα 14: Configuration Device tracking



Εικόνα 15:config account recovery

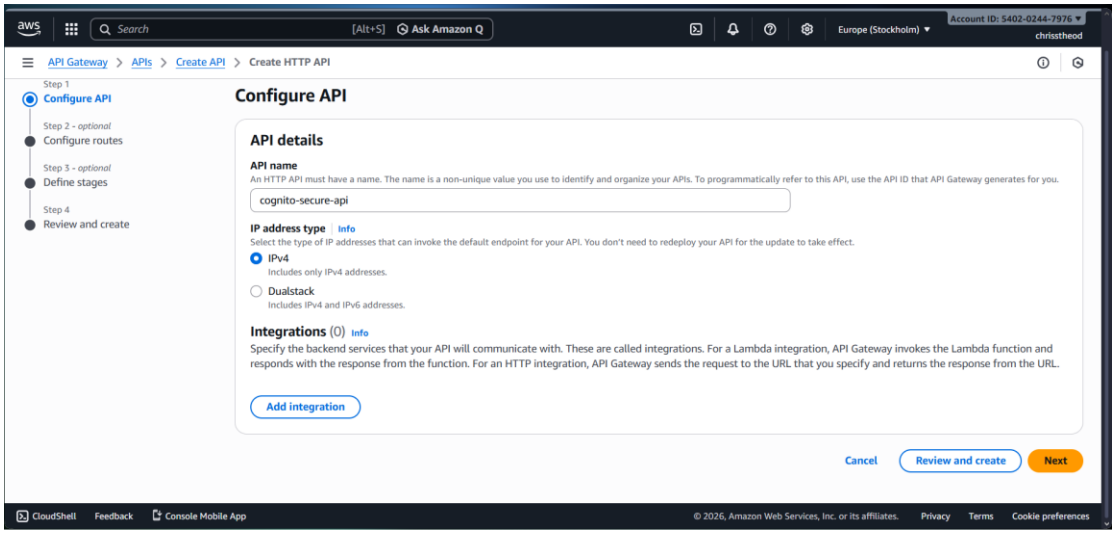


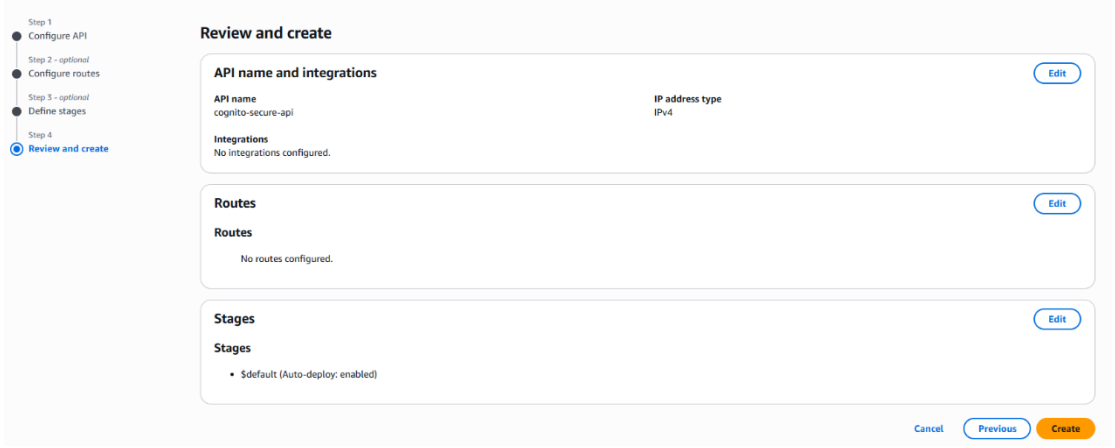
Εικόνα 16:login pages configuration

B. API Gateteway config

Βήμα 1: Δημιουργία του API Gateway

Έγινε αρχική δημιουργία με απλές ρυθμίσεις χωρίς routes ,integrations & stages και αργότερα προστέθηκαν όλα τα απαραίτητα configurations.

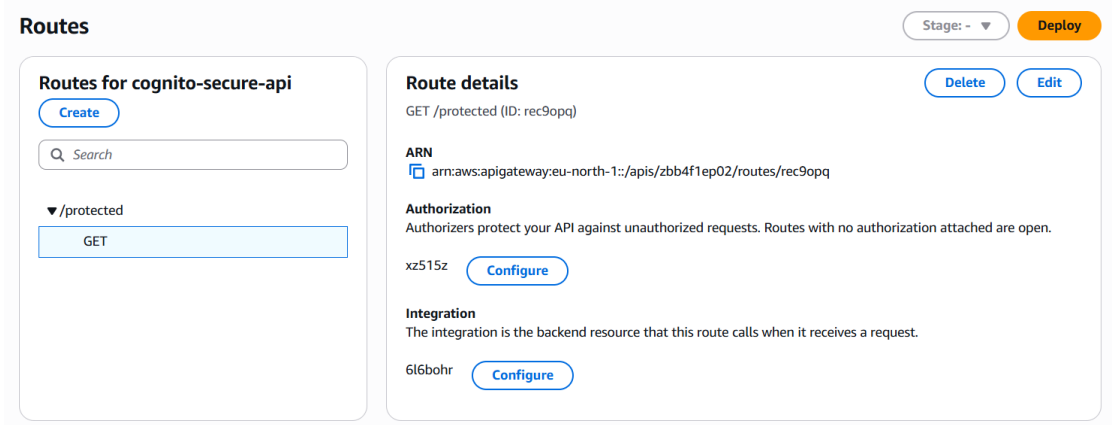




Εικόνα 17&18:Βήματα για την δημιουργία του API

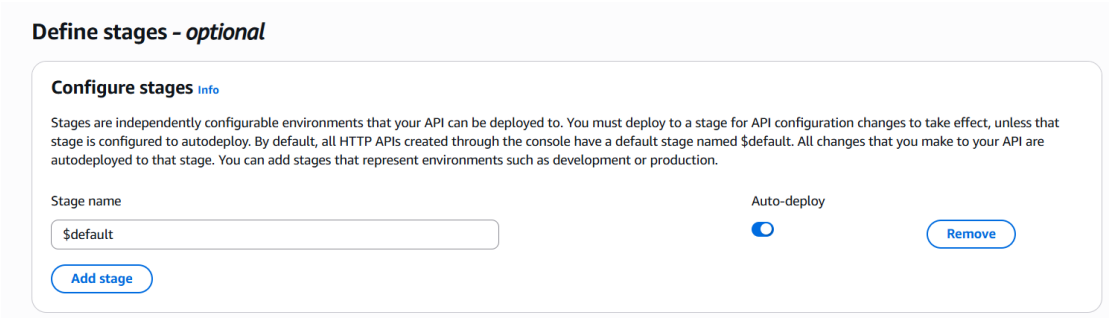
Βήμα 2: Δημιουργία των Routes & Stages

Έγινε configuration με μέθοδο **GET** και route: **/protected**



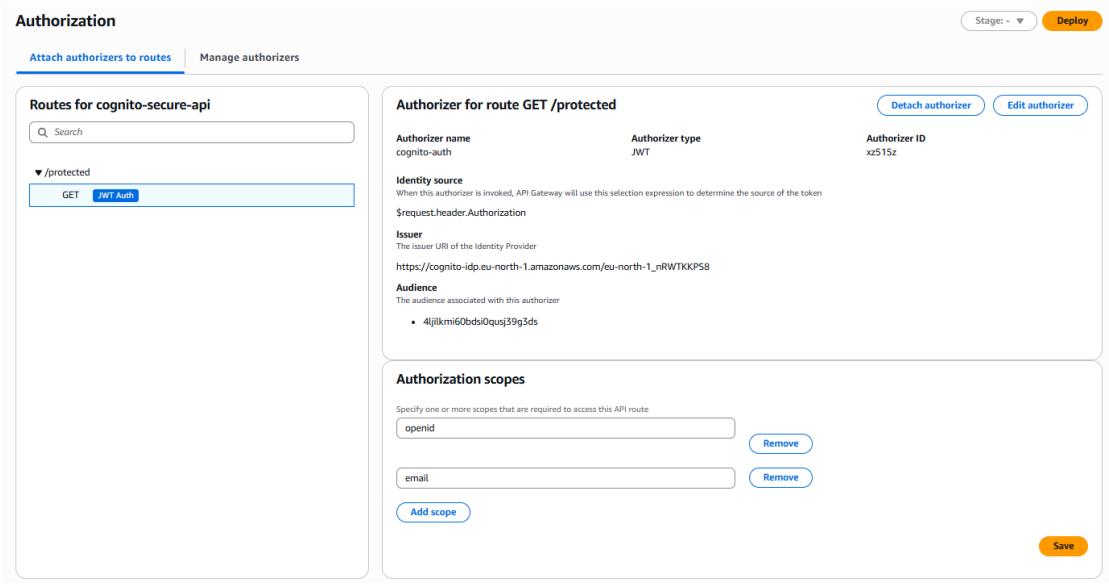
Εικόνα 19: Routes configuration

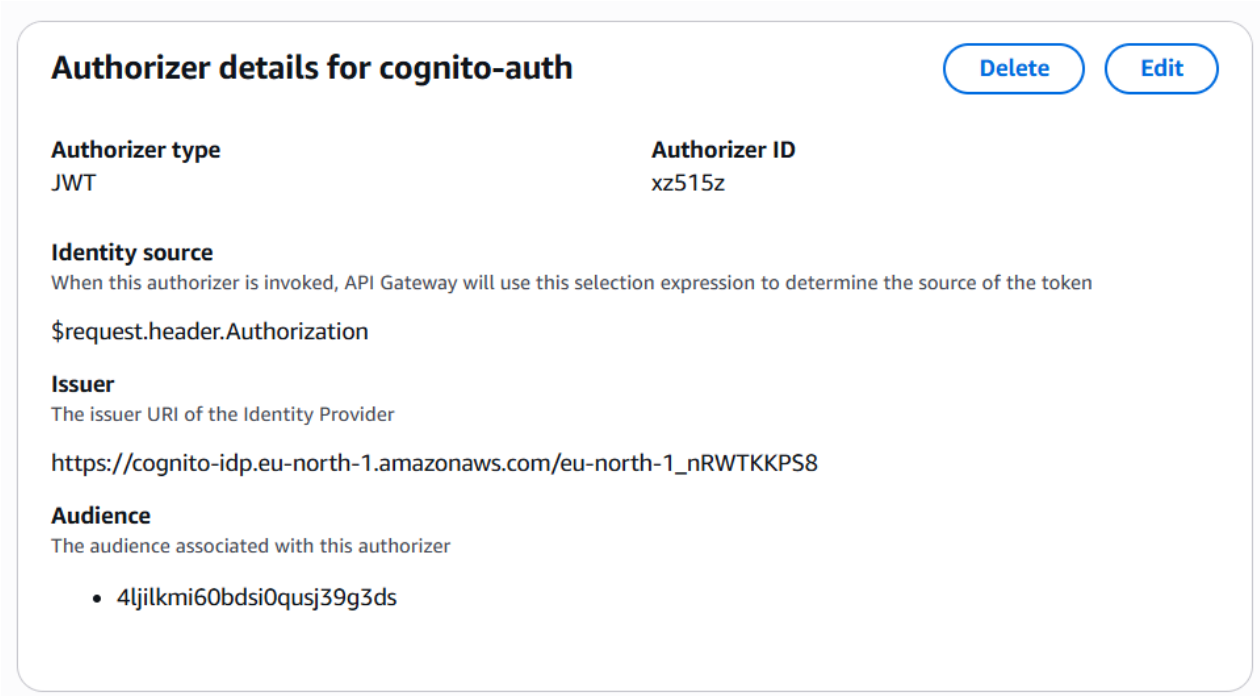
Το API αναπτύχθηκε σε default stage του API Gateway με ενεργοποιημένο auto-deployment, επιτρέποντας την άμεση εφαρμογή αλλαγών.



Εικόνα 20: Stages configuration

Βήμα 3:Authorization



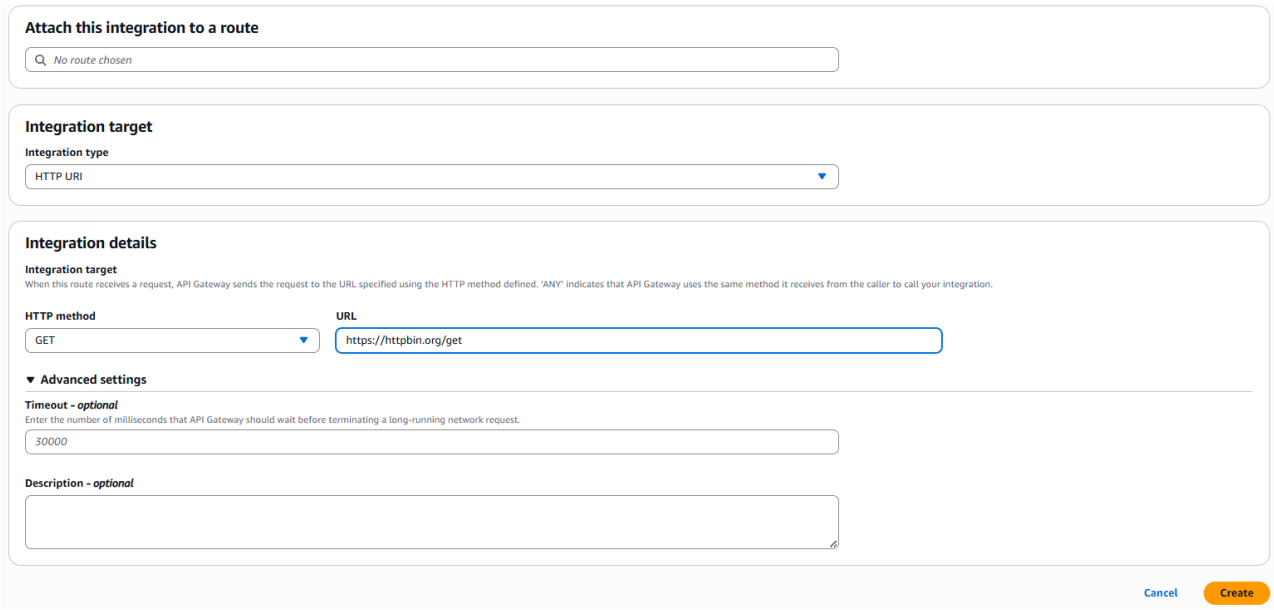


Εικόνα 21 και 22:Authorizer config & details

Βήμα 4 :Integrations

HTTP URL Integration :

«Για το case study χρησιμοποιήθηκε HTTP API Gateway με HTTP URL Integration σε test endpoint, ώστε να αξιολογηθεί αποκλειστικά ο μηχανισμός authentication και authorization μέσω Amazon Cognito, χωρίς υλοποίηση backend.Το συγκεκριμένο Integration με URL: https://httpbin.org/get ελέγχει πρώτα το Amazon Cognito,αν περάσει η σύνδεση κάνει forward στο URL του : https://httpbin.org/get (μέσα από το Allowed callback URLs) με JWT Bereal token ,αλλιώς βγάζει μήνυμα 401 “unauthorized” λόγο του ότι λείπει το authentication token.»



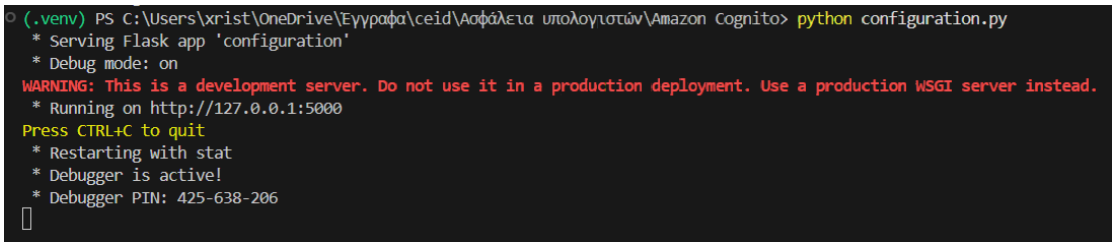
Εικόνα 23:Integration configuration



Εικόνα 24: Integration πληροφορίες

Βήμα 5 :Review & Testing

Το wep app cognito τρέχει τοπικά στον υπολογιστή με ένα python script όπου περιέχει το configuration το όποιο δόθηκε από το AWS console από το Quick Set up guide του web app.(πηγή: https://eu-north-1.console.aws.amazon.com/cognito/v2/idp/user-pools/eu-north-1_nRWTKKPS8/applications/app-clients/4ljilkmi60bdsi0qusj39g3ds/quick-setup-guide?region=eu-north-1).



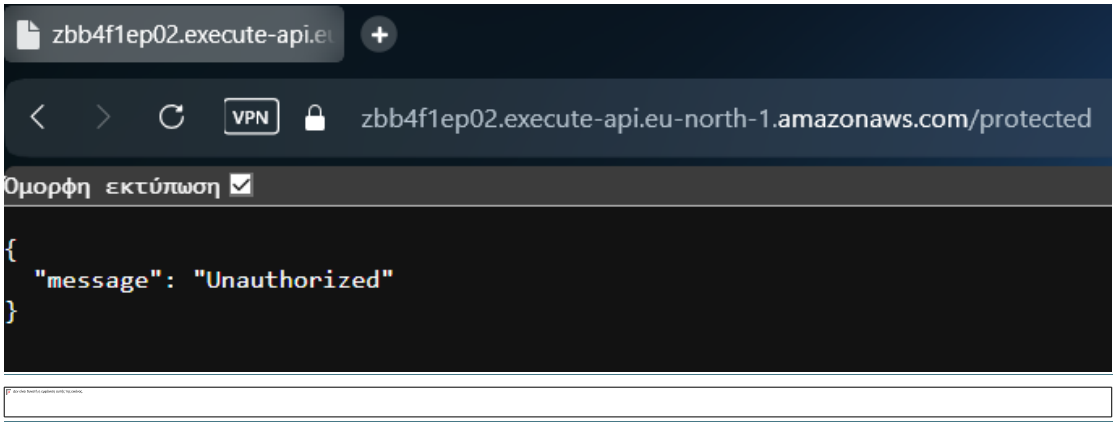
Εικόνα 25:compile του configuration.py

Η ασφάλεια του API επαληθεύτηκε μέσω δοκιμών πρόσβασης. Χωρίς JWT token το API επιστρέφει HTTP 401, ενώ με έγκυρο access token από το Amazon Cognito επιτρέπεται η πρόσβαση και επιστρέφεται HTTP 200 με μήνυμα JSON απάντησης από httpbin.

Τεστάρουμε το API χώρις token με μέθοδο get σε αυτό το url: https://zbb4f1ep02.execute-api.eu-north-1.amazonaws.com/protected

Χωρίς JWT token στο url:

https://zbb4f1ep02.execute-api.eu-north-1.amazonaws.com/protected

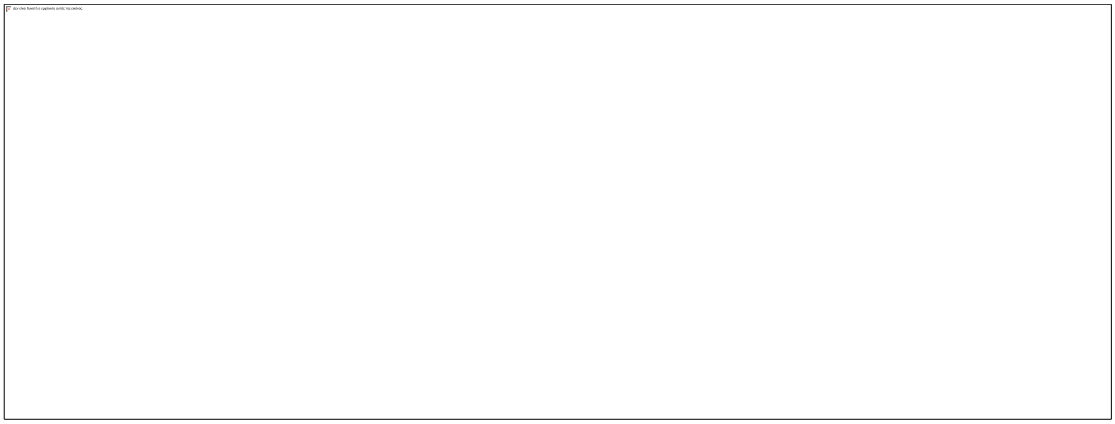


Εικόνα 26 και 27: 401 Error message χωρίς token

Με Bereal JWT token:

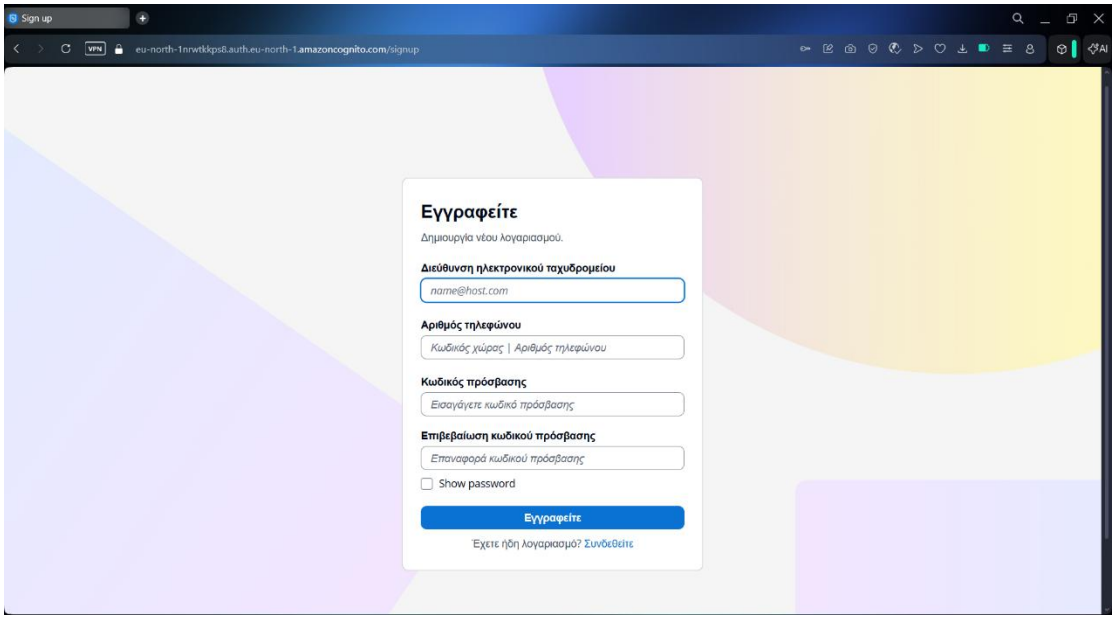
Τρέχουμε την **εντολή**: curl -X GET "https://zbb4f1ep02.execute-api.eu-north-1.amazonaws.com/protected" -H "Authorization: <τρέχον JWT_token>"

Στο terminal:



Εικόνα 28: 200 JSON message με JWT Bereal token

Login page URL: https://eu-north-1nrwtkkps8.auth.eu-north-1.amazoncognito.com/login?client_id=4ljilkmi60bdsi0qusj39g3ds&response_type=token&scope=email+openid+phone&redirect_uri=https%3A%2F%2Fjwt.ios



Εικόνα 29: Σελίδα φόρμας εγγραφής



Εικόνα 30: Σελίδα σύνδεσης